

Módulo 2: Vulnerabilidades de Inyección

T04: SQL Injection

Carlos Rodríguez Contreras · GitHub: [karrocon](#)

 *El ataque de inyección más clásico — y más devastador*

Objetivos

- Entender cómo funciona SQL Injection a nivel de query
- Explotar el login de VulnApp con payloads clásicos
- Realizar un Blind SQLi básico
- Corregir la vulnerabilidad con prepared statements

En construcción

Este topic todavía no tiene slides completas.

Usa las diapositivas maestras (`slides-curso.html`) como referencia del contenido previsto.



Lab T04: SQL Injection en el login

Objetivo: explotar el login de VulnApp y luego aplicar el fix

Setup: `cd VulnApp && npm start` → `http://localhost:3000/login`

1. Introduce `' OR 1=1 --` como usuario (cualquier contraseña)
2. Observa que accedes sin credenciales válidas
3. Abre `src/routes/auth.ts` y aplica prepared statements
4. Verifica que el payload ya no funciona

⚠ Solo en entorno local. Nunca en sistemas reales sin autorización.